

Cloud & IT Vendor Due Diligence — General Baseline

Version: Pre-amendment / baseline

Scope: General cloud and IT suppliers; no amendment-specific controls.

Instructions: Tick the checkbox when the item is completed and record evidence/findings in the space provided.

Governance

☐ Due diligence check	Evidence / notes
☐ Does the vendor maintain a documented information-security governance framework with executive accountability?	
☐ Is there a named security owner and defined escalation process for material incidents?	
☐ Are security obligations flowed down to subcontractors and material suppliers?	

Risk Management

☐ Due diligence check	Evidence / notes
☐ Does the vendor perform periodic cyber risk assessments covering its services to the customer?	
☐ Are critical findings tracked to remediation with accountable owners and target dates?	
☐ Is there an independent assurance programme such as SOC 2, ISO 27001, or equivalent?	

Access Control

☐ Due diligence check	Evidence / notes
☐ Are privileged accounts strongly authenticated and reviewed periodically?	
☐ Are joiner/mover/leaver processes documented and tested?	

Data Protection

☐ Due diligence check	Evidence / notes
☐ Is customer data classified and protected in transit and at rest?	
☐ Are retention, deletion, backup and restoration controls defined?	

Resilience & Incident Response

☐ Due diligence check	Evidence / notes
☐ Does the vendor maintain tested business continuity and disaster recovery plans?	

■	Due diligence check	Evidence / notes
■	Does the vendor have a documented cyber incident response process and customer notification procedure?	

Supply Chain

■	Due diligence check	Evidence / notes
■	Does the vendor assess security risks of critical subcontractors and technology providers?	
■	Can the vendor identify dependencies that could affect availability, confidentiality or integrity of the service?	

Reviewer sign-off Name: _____ Date: _____ Overall risk: ■ Low ■ Medium ■ High ■ Critical